Inicio de sesión con Microsoft (SSO) en las apps internas de Craze

Guía de configuración y mantenimiento · Válida para cualquier app web propia · Actualizada el 28/10/2026

En esta guía

Valor de ejemplo	Sustituir por
`<app>`	Nombre de la app (p. ej. Craze Finance)
`<dominio>`	Dirección pública de la app (p. ej. craze-finance.vercel.app o finance.craze-group.com)
`<repo>`	Repositorio de GitHub de la app (p. ej. CrazeGroup/craze-finance)

Los pasos se refieren a Azure (Entra ID), Vercel y GitHub, el entorno que usamos habitualmente. Si la app se aloja en otro sitio, las variables son las mismas y solo cambia la pantalla donde se introducen. Como referencia sirve **Craze Finance**, que ya lo tiene implantado (código en `src/app/api/auth/microsoft/`, `src/lib/auth.ts` y `src/middleware.ts`).

1. Cómo funciona

El usuario pulsa **Iniciar sesión con Microsoft**, se identifica con su cuenta de Craze en Microsoft y vuelve a la app. La app comprueba con Microsoft que la identidad es auténtica y la busca en su propia lista de usuarios por el correo. Si el correo está dado de alta, abre una sesión con los permisos de ese usuario. Si no lo está, lo rechaza.

Así Microsoft dice *quién* es el usuario y la app decide *qué* puede hacer. Cada app tiene su propio registro en Azure, su propio client secret y su propia lista de usuarios. No se comparten entre apps.

2. Registrar la app en Azure (Entra ID)

Se hace una vez por app, con una cuenta con permiso para registrar aplicaciones en el directorio de Craze.

1. portal.azure.com > **App registrations** > **New registration**.
2. Nombre: `<app>`. Tipo de cuenta: **Single tenant** (solo el directorio de Craze).
3. Redirect URI, tipo **Web**: `https://<dominio>/<ruta de vuelta>`. En nuestras apps la ruta es `/api/auth/microsoft/callback`. Debe coincidir carácter a carácter con la que envía la app. Si la app se usa en varias direcciones (dominio propio, local con `http://localhost:3000`), se añade una URI por cada una en **Authentication**.
4. En **Overview** copiar **Directory (tenant) ID** y **Application (client) ID**.
5. **Certificates & secrets** > **Client secrets** > **New client secret** (caducidad 24 meses). Copiar la columna **Value** en ese momento, porque después ya no se puede ver. **No** es el "Secret ID".
6. No hace falta añadir permisos: openid, profile y email vienen por defecto.
7. Opcional: en **Enterprise applications** > `<app>` > **Properties**, "Assignment required" = Yes y asignar en **Users and groups** quién puede usarla. Así Microsoft corta el paso antes de llegar a la app.

Importante: apuntar en el calendario la fecha de caducidad del client secret. Cuando caduca, nadie puede entrar con Microsoft hasta que se cree uno nuevo y se actualice en el alojamiento de la app (apartado 9).

3. Variables de entorno

En Vercel: proyecto > **Settings** > **Environment Variables**, entorno **Production**. Las contraseñas y tokens se guardan como **Secret** y el interruptor como **Config**. Tras añadir o cambiar cualquier variable hay que hacer **Deployments > ... > Redeploy**, porque si no, no se aplica.

Variable	Valor	Para qué sirve
`AZURE_AD_TENANT_ID`	Directory (tenant) ID	Identifica el directorio de Microsoft de Craze. Es el mismo en todas las apps.
`AZURE_AD_CLIENT_ID`	Application (client) ID	Identifica el registro de esta app en Azure.
`AZURE_AD_CLIENT_SECRET`	El **Value** del client secret	Contraseña de la app ante Microsoft. Caduca.
`JWT_SECRET`	Texto aleatorio largo	Firma la cookie de sesión de la app. Si se filtra, se podrían falsificar sesiones. Cambiarlo cierra todas las sesiones.
`INTERNAL_API_TOKEN`	Texto aleatorio largo	Solo si hay procesos automáticos (sincronizaciones, cron, scripts) que llaman a la API sin usuario. Mismo valor en el proceso que llama.
`AUTH_ENABLED`	`true`	Interruptor del login. Permite preparar todo antes y apagarlo si algo falla.

Para generar los valores aleatorios, en la terminal del Mac: `openssl rand -base64 48` (una vez por variable, valores distintos y distintos en cada app). Da igual en qué ordenador se generen. No pegarlos en chats ni correos. Si se ha hecho, generar otro.

4. Procesos automáticos (si los hay)

Con el login activo, cualquier tarea que llame a la API de la app sin usuario (p. ej. un workflow de GitHub Actions que sincroniza datos) recibe un error 401. Debe enviar la cabecera `Authorization: Bearer <INTERNAL_API_TOKEN>`.

1. GitHub: `<repo>` > **Settings** > **Secrets and variables** > **Actions** > **New repository secret**. Name `INTERNAL_API_TOKEN`, Secret = el mismo valor que en Vercel.
2. En el workflow, leerlo como `${{ secrets.INTERNAL_API_TOKEN }}` y añadirlo a cada llamada.
3. Comprobar con **Actions** > el workflow > **Run workflow** que todas las llamadas devuelven 200.

Para subir cambios a la carpeta `.github/workflows` desde el Mac, el token personal de GitHub (github.com/settings/tokens) necesita el permiso **workflow** además de **repo**. Si falta, GitHub rechaza el push con "refusing to allow a Personal Access Token to create or update workflow".

5. Usuarios

- El nombre de usuario es el **correo de Microsoft** (nombre.apellido@craze-group.com). La comparación no distingue mayúsculas.
- Lo recomendable es dar de alta a los usuarios **sin contraseña**: solo pueden entrar con Microsoft. Si la persona sale de la empresa y se desactiva su cuenta de Microsoft, deja de poder entrar en todas las apps a la vez.
- A cada usuario se le asignan sus permisos (módulos o funciones). Debe existir al menos un **administrador** con su correo antes de activar el login.
- Revisar si la app trae usuarios de prueba o iniciales (p. ej. "admin" / "admin") y eliminarlos o quitarles la contraseña antes de activar el login.

6. Activar, comprobar y desactivar

1. Con el registro de Azure, las variables, el token de los procesos automáticos y el administrador listos: añadir `AUTH_ENABLED = true` y hacer Redeploy.
2. Abrir la app en una ventana privada: debe mostrar la pantalla de login. Pulsar **Iniciar sesión con Microsoft** y elegir la cuenta de Craze.
3. Comprobar que se entra con los permisos correctos y que el inicio de sesión queda en el registro de actividad, si la app lo tiene.
4. Ejecutar a mano los procesos automáticos y comprobar que no dan 401.
5. Para desactivar el login en caso de problema: poner `AUTH_ENABLED` a `false` (o borrarla) y Redeploy.

7. Qué tiene que implementar la app (para el desarrollador)

Flujo OpenID Connect "authorization code" contra `https://login.microsoftonline.com/<tenant>/oauth2/v2.0/`, sin librerías de terceros además de una de JWT (en Craze Finance, *jose*):

- **Ruta de inicio** (`/api/auth/microsoft`): genera *state* y *nonce* aleatorios, los guarda en una cookie httpOnly de 10 min y redirige a `/authorize` con `response_type=code`, `scope=openid profile email`, redirect URI y `prompt=select_account`.
- **Ruta de vuelta** (`/api/auth/microsoft/callback`): comprueba que el *state* coincide, canjea el *code* en `/token` con el client secret y verifica el *id_token*: firma con las claves del tenant, *issuer*, *audience* = client ID y *nonce*. Issuer y claves se leen del documento `/<tenant>/v2.0/.well-known/openid-configuration`, así sirve tanto el GUID del tenant como el dominio.
- **Correo**: tomarlo de `preferred_username` (o `email` / `upn`), buscarlo en la tabla de usuarios sin distinguir mayúsculas y, si no existe, rechazar el acceso. No crear usuarios automáticamente.
- **Sesión**: cookie propia firmada con `JWT_SECRET` (httpOnly, secure, 24 h) con el id, usuario y permisos. A partir de aquí la app no vuelve a hablar con Microsoft.
- **Protección**: un middleware que, con `AUTH_ENABLED=true`, manda al login a quien no tenga sesión, responde 401 en la API y deja pasar las llamadas con el `INTERNAL_API_TOKEN`. Las rutas de login y de vuelta deben ser públicas.
- **Errores**: volver a la pantalla de login con un código y, si lo hay, el motivo de Microsoft (p. ej. AADSTS7000215), para poder diagnosticar sin mirar logs.

8. Problemas frecuentes

Síntoma	Causa probable	Solución
"No está configurado"	Falta alguna variable AZURE_AD_* o no se hizo Redeploy.	Revisar las tres variables y redesplegar.
"Tu cuenta no tiene acceso"	Ese correo no está en los usuarios de la app.	Darlo de alta con su correo de Microsoft.
AADSTS7000215 / 7000222	Client secret incorrecto (se puso el Secret ID) o caducado.	Crear un client secret nuevo, copiar el **Value**, actualizar `AZURE_AD_CLIENT_SECRET` y Redeploy.
AADSTS50011 en la página de Microsoft	La Redirect URI no coincide con la dirección de la app.	Añadir la URI exacta en Azure > Authentication.
AADSTS50105	"Assignment required" activo y el usuario no está asignado.	Asignarlo en Enterprise applications > Users and groups.
"La sesión ha caducado"	Más de 10 min en la página de Microsoft o cambio de dominio a mitad.	Volver a pulsar Iniciar sesión con Microsoft.
Procesos automáticos con 401	INTERNAL_API_TOKEN distinto o ausente en quien llama.	Igualar ambos valores y redesplegar.
La app sigue abierta sin login	AUTH_ENABLED no es exactamente "true" o falta Redeploy.	Corregir el valor y redesplegar.

9. Mantenimiento

- **Client secret:** renovarlo antes de que caduque (Azure > Certificates & secrets). Crear el nuevo, actualizar el alojamiento, Redeploy y después borrar el antiguo.
- **Inventario:** mantener una lista de las apps con SSO, su client ID, dónde están alojadas y la fecha de caducidad de su secret.
- **Altas y bajas:** dar de alta o baja el usuario en cada app. Desactivar la cuenta de Microsoft impide entrar en todas.
- **Valores secretos:** no se guardan en documentos. Solo en Azure, en el alojamiento de la app y, si aplica, en GitHub.